

Incident Report:

Boss of the SOC Version 1

Web site defacement

This document demonstrates my approach to investigating and writing incident reports as I continue developing my skills in cybersecurity, SOC analysis, and incident response.

The investigation findings are supported by the available logs and evidence; however, some events and response actions described after the initial compromise are hypothetical and were created to demonstrate how the incident could realistically be handled in a real-world environment.

Table of Contents

Real-world Incident Report

I.	Executive Summary	2
II.	Technical Analysis	4
	2.1 Affected Systems & Data	4
	2.2 Evidence Sources & Analysis	4
	2.3 Indicators of Compromise (IoCs)	7
	2.4 Root Cause Analysis	8
	2.5 Technical Timeline	8
	2.6 Nature of the Attack	10
III.	Impact Analysis	11
IV.	Response and Recovery Analysis	11
	4.1 Immediate Response Actions	11
	4.2 Eradication Measures	11
	4.3 Recovery Steps	12
	4.4 Post-Incident Actions	12
V.	Lesson Learned	13

I. Executive Summary

- **Incident ID:** (N/A this is a home lab)
- **Incident Severity:** High (P2)
- **Incident Status:** Resolved
- **Incident Overview:** On August 10, 2016, the website www.imreallynotbatman.com was compromised by a group identified as Po1s0n1vy. The investigation found that the group used a web vulnerability scanner at approximately 21:37 UTC to identify weaknesses, downloaded files from an external malicious site prankglassinebracket.jumpingcrab.com, a malicious executable into the web directory and made repeated attempts to gain access, resulting in unauthorized access and the defacement of the website.
 - www.imreallynotbatman.com: the personal blog website operated by Wayne Enterprises that has been compromised and defaced.
 - prankglassinebracket.jumpingcrab.com: malicious domain associated with the attacker group.

Security Analyst, in collaboration with the Digital Forensics and Incident Response (DFIR) units, managed successfully to contain the threat, remove the images used in defacement, and restore the compromised website to their original state. (This is only a sample make-up after the incident occurs since this is home lab exercise).

- **Key Findings:** Two malicious IPv4 addresses were found; one was associated with the web vulnerability scan, while the other is associated with brute force attack. HTTP logs identified Acunetix scanning activity against the Joomla application. The scanning activity likely identified weaknesses that assisted the attacker in subsequent exploitation and conducted repeated attempts that ultimately led to unauthorized access to the website's administration system. The attackers then upload payloads for remote access and fetch the defacement image from their malicious website and use it to deface the compromised website.
- **Immediate Actions:** Since this investigation is based on a simulated incident and is not an actual security incident, the following possible actions are based on the findings. The security team would likely isolate the affected website from the other system hosted in Wayne Enterprise to prevent the incident from spreading and causing more damage. During investigations, the affected website could be temporarily taken offline or restricting access. This includes securing the website administration account by resetting affected credentials, removing unauthorized or malicious files, and restoring website content to its original state. In addition, relevant logs and evidence would be preserved to support further investigations and determine other scope of compromise. The event logs would be automatically collected by the existing Elastic SIEM solution for in real time monitoring, analysis, and further investigations.
- **Stakeholder Impact:**
 - Customers: The unauthorized access in the system administration raises concerns about the integrity and confidentiality of customer data. No direct evidence of customer-data exposure was identified in the available logs. However, because unauthorized administrative access was achieved, potential access to website data and associated administrative resources should be considered during a full forensic investigation.

- Employees: Although the administrator was specifically targeted or extracted, the potential risk remains. Employees may be subject to identity theft or phishing attacks if their data was compromised.
- Business Partners: The website www.imreallynotbatman.com is a personal blog that was compromised and a possibility that proprietary code could have been exposed. This could have ramifications for business partners who rely on the integrity and exclusivity of Wayne Enterprises.
- Regulatory Bodies: Regulatory bodies may impose fines or sanctions for failing to adequately protect sensitive data, conduct regular vulnerability and security assessments, expose administrative control portals publicly and enforce appropriate security controls, such as strong password policies. The specific penalties would depend on the jurisdiction and the nature of the compromised data.
- Internal Teams: The SOC and DFIR teams were able to contain the threat effectively, but the incident will likely necessitate a review and potential overhaul of current security measures. This could mean a reallocation of resources and budget adjustments, impacting other departments and projects.
- Shareholders: The web defacement incident could negatively affect shareholder confidence due to potential reputational damage, customer concerns, and the possible costs associated with investigating and recovering from the compromise. The impact would depend on how Wayne Enterprises responds to the incident, addresses the security weaknesses, and restores stakeholder confidence.

II. Technical Analysis

2.1 Affected Systems & Data

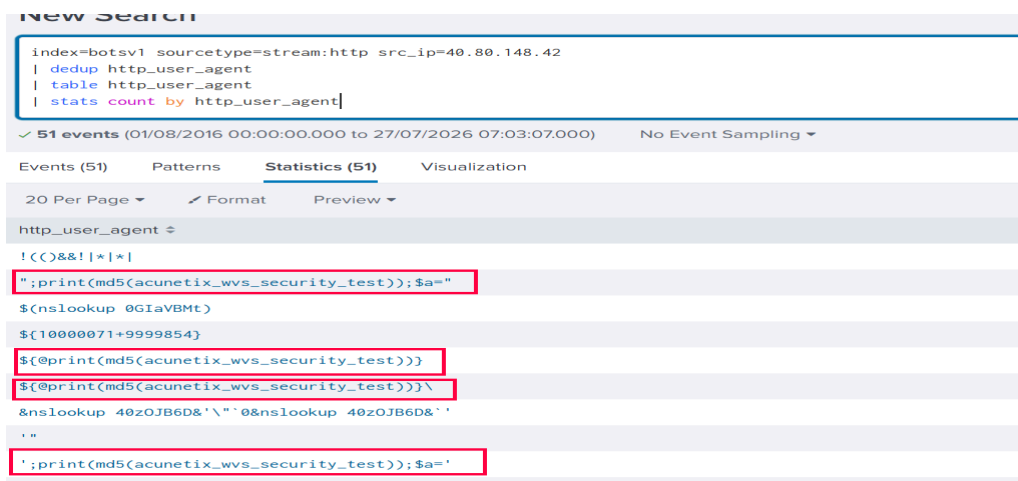
The investigation found that the attacker first used a acunetix web vulnerability scanner to identify potential weaknesses in the www.imreallynotbatman.com website and found publicly exposed administrative login endpoints. Then the attacker proceeded with exploitation attempts and conducted repeated brute-force attempts against the website's administration system.

The investigation also found evidence after the attacker successfully guessed the administrative credentials, and used native administrator privileges to retrieve images and upload malicious payloads from their external malicious domain controlled by the attacker. The following systems and domains were identified as relevant to the incident:

- **Affected Website:** www.imreallynotbatman.com— the compromised website operated by Wayne Enterprises.
- **External Malicious Website:** prankglassinebracket.jumpingcrab.com — an external site associated with the attack that was used to host or provide files retrieved by the compromised server.

2.2 Evidence Sources & Analysis

On August 10, 2016, a memo from the Gotham City Police Department found evidence online that the website hosted by Wayne Enterprises had been compromised. At approximately 21:37 UTC, the Security team confirmed that the website had been compromised and defaced. The investigation identified the reconnaissance phase, in which an IPv4 address belonging to someone from the Pols0n1vy group was scanning imreallynotbatman.com for web application vulnerabilities. This was investigated using Splunk Enterprise, as displayed in the following screenshot.



```
New Search
index=botsv1 sourcetype=stream:http src_ip=40.80.148.42
| dedup http_user_agent
| table http_user_agent
| stats count by http_user_agent

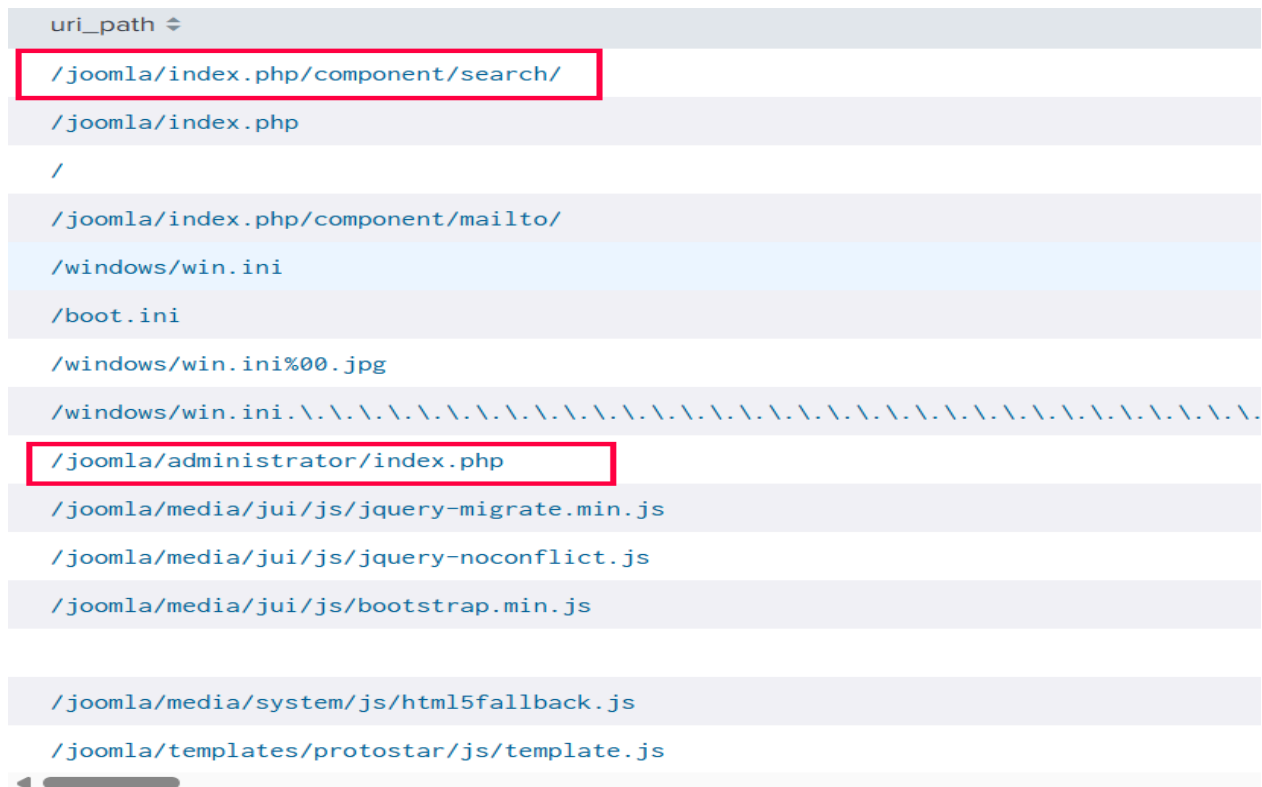
✓ 51 events (01/08/2016 00:00:00.000 to 27/07/2026 07:03:07.000) No Event Sampling ▼

Events (51) Patterns Statistics (51) Visualization
20 Per Page ▼ Format Preview ▼
http_user_agent
!(<>&!|*|*|
";print(md5(acunetix_wvs_security_test));$a="
$(nslookup 0GIaVBMT)
${10000071+9999854}
${@print(md5(acunetix_wvs_security_test))}
${@print(md5(acunetix_wvs_security_test))}\
&nslookup 40z0JB6D&"'0&nslookup 40z0JB6D&"'
'
';print(md5(acunetix_wvs_security_test));$a="
```

From the logs, it contains the string `acunetix_wvs` which is the Acunetix as the company name that develops the web vulnerability scanner used by the attacker. The IPv4 address they used to scan web vulnerabilities is `40.80.148.42`, indicating it discovered exposed weaknesses in the web application. It

is likely confirmed because of the vulnerability scanner identified or retrieved information containing an MD5 hash.

Further investigations found that they identified exposed administrator login credentials publicly in the Joomla Content Management System (CMS). The following screenshots show Acunetix testing the Joomla search component for exposed vulnerabilities:



The Reconnaissance phase of the attacker group are the following:

- The use of automated web vulnerability scanner called Acunetix
- The attacker discovered two key details before exploitation:
 1. The scanner identified that the website was running an unpatched version of the Joomla Content Management System (CMS)
 2. It located the specific, exposed administrative login page backend (/administrator/index.php), which lacked account lockout policies.

Following the reconnaissance phase, the attackers confirmed the default **admin** username and switched tactics by using a separated IP address to execute the brute-force attack.

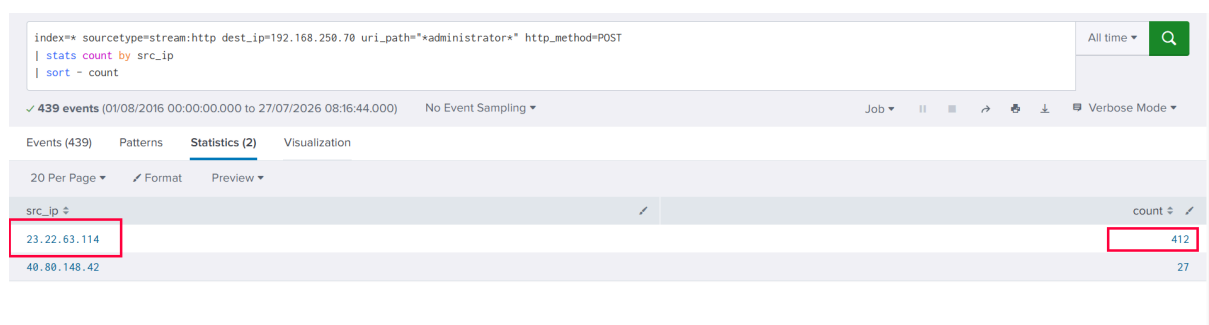
Host Analysis — 192.168.250.70

From the logs, we identified two malicious IP addresses with a destination to the host **192.168.250.70**, a website hosted by Wayne Enterprises (www.imreallynotbatman.com).

IP	Hostname
40.80.148.42	
23.22.63.114	prankglassinebracket.jumpingcrab.com

The following screenshots is the result of a Splunk that shows the classic Cyber Kill Chain sequence to fully compromise the 192.168.250.70 (www.imreallynotbatman.com).

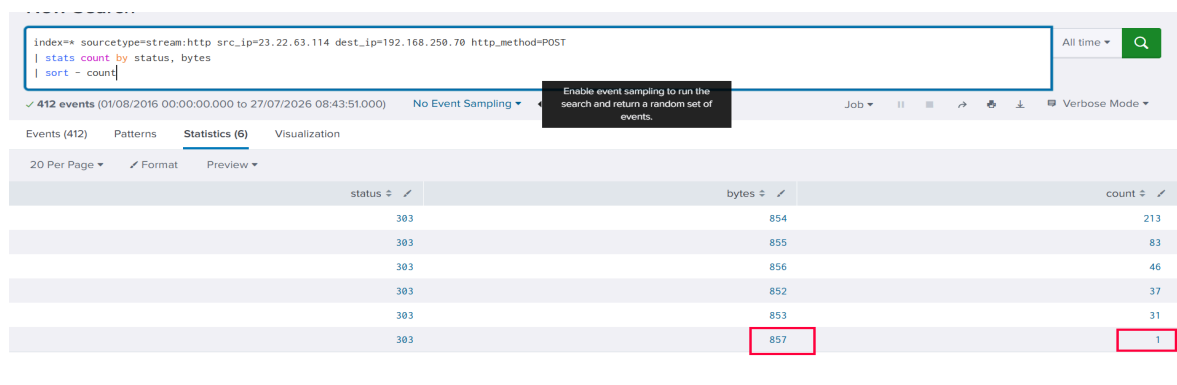
Brute-Force Password Attack Against imreallynotbatman.com



src_ip	count
23.22.63.114	412
40.80.148.42	27

It appears the IP address attempting a brute force password attack against [imreallynotbatman.com](http://www.imreallynotbatman.com) is **23.22.63.114** with a very high count of requests to the admin login page.

In addition, to confirm this is likely a brute force attempt. We can see the following screenshots result, where every other byte-size value (852–856) has dozens or hundreds of occurrences and a normal repeated "failed login" response. But 857 appears exactly once, breaking the pattern entirely:

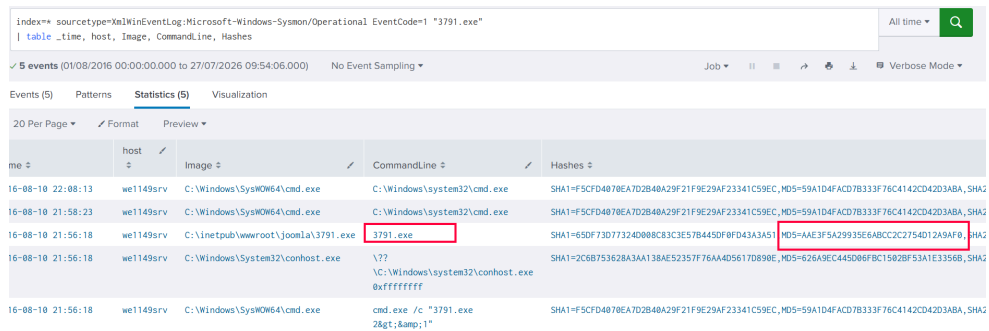


status	bytes	count
303	854	213
303	855	83
303	856	46
303	852	37
303	853	31
303	857	1

Joomla administrator login

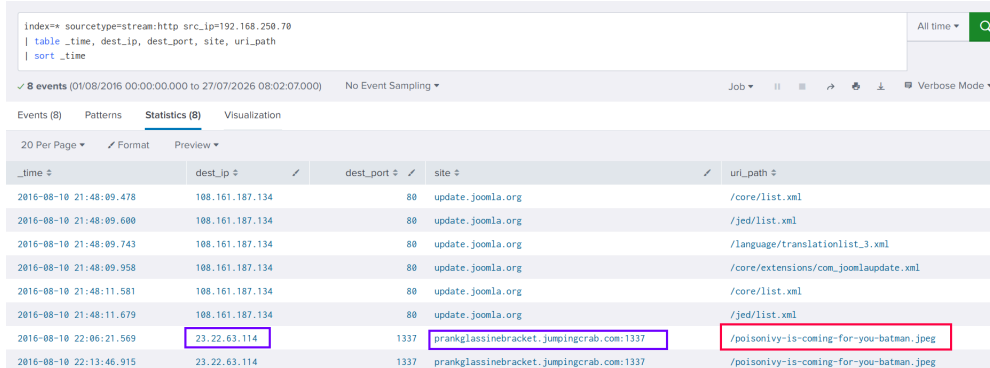
The following where attackers had already gained access to the Joomla administration dashboards:

- The compromised web server communicated with attacker-controlled external infrastructure to retrieve malicious files from `prankglassinebracket.jumpingcrab.com` (IP address 23.22.63.114), which were then used to issue commands to the compromised system.
- The attacker exploited a file upload vulnerability to install malicious payloads primarily `3791.exe`.



Time	Host	Image	CommandLine	Hashes
16-08-10 22:08:13	we1149srv	C:\Windows\SysWOW64\cmd.exe	C:\Windows\system32\cmd.exe	SHA1=F5CFD4078EA702B48A29F21F9E29AF23341C59EC, MD5=59A1D4FACD7B333F76C4142CD42D3ABA, SHA2
16-08-10 21:58:23	we1149srv	C:\Windows\SysWOW64\cmd.exe	C:\Windows\system32\cmd.exe	SHA1=F5CFD4078EA702B48A29F21F9E29AF23341C59EC, MD5=59A1D4FACD7B333F76C4142CD42D3ABA, SHA2
16-08-10 21:56:18	we1149srv	C:\inetpub\wwwroot\joomla\3791.exe	3791.exe	SHA1=650F73D77324D088C3C57B445D8F0FD43A51, MD5=AAE3F5A29935E6ABCC2C2754D12A9AF8, SHA2
16-08-10 21:56:18	we1149srv	C:\Windows\System32\conhost.exe	\?? C:\Windows\system32\conhost.exe 0xffffffff	SHA1=2C6B753628A3A138AE52357F76AA4D5617D898E, MD5=626A9EC445D06FBC1582BF53A1E3356B, SHA2
16-08-10 21:56:18	we1149srv	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "3791.exe 2>&1;"	SHA1=F5CFD4078EA702B48A29F21F9E29AF23341C59EC, MD5=59A1D4FACD7B333F76C4142CD42D3ABA, SHA2

- Using the web server `imreallynotbatman.com`, the attacker reached out to fetch a file and sent a GET request to their own external host, pulling the defacement image `poisonivy-is-coming-for-you-batman.jpeg`.



Time	Dest IP	Dest Port	Site	URI Path
2016-08-10 21:48:09.478	108.161.187.134	80	update.joomla.org	/core/list.xml
2016-08-10 21:48:09.600	108.161.187.134	80	update.joomla.org	/jed/list.xml
2016-08-10 21:48:09.743	108.161.187.134	80	update.joomla.org	/language/translationlist.3.xml
2016-08-10 21:48:09.958	108.161.187.134	80	update.joomla.org	/core/extensions/com_joomlaupdate.xml
2016-08-10 21:48:11.581	108.161.187.134	80	update.joomla.org	/core/list.xml
2016-08-10 21:48:11.679	108.161.187.134	80	update.joomla.org	/jed/list.xml
2016-08-10 22:06:21.569	23.22.63.114	1337	prankglassinebracket.jumpingcrab.com:1337	poisonivy-is-coming-for-you-batman.jpeg
2016-08-10 22:13:46.915	23.22.63.114	1337	prankglassinebracket.jumpingcrab.com:1337	poisonivy-is-coming-for-you-batman.jpeg

2.3 Indicators of Compromise (IoCs)

IoC Type	Indicator	Description
Source IP	40.80.148.42	Vulnerability scanning activity
Source IP	23.22.63.114	Brute-force / malicious infrastructure
Domain	prankglassinebracket.jumpingcrab.com	External attacker infrastructure
File	3791.exe	Suspicious payload

File	MirandaTateScreensaver.scr.exe	Malicious file identified during analysis
File	poisonivy-is-coming-for-you-batman.jpeg	Defacement image
Hash	9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8	SHA-256 associated with malicious artifact
Hash	AAE3F5A29935E6ABCC2C2754D12A9AF0	MD5 hash of the executable uploaded

2.4 Root Cause Analysis

The investigation determined that the compromise was primarily caused by weaknesses in the Joomla Content Management System (CMS) and insufficient security controls surrounding administrative access. The web vulnerability scan identified weaknesses in the web application, which allowed the attackers to further target the Joomla administration interface. The attackers then performed repeated authentication attempts and were able to obtain unauthorized access to the administrator account. Once access was established, insufficient restrictions on file uploads and web application activity allowed the attackers to upload or retrieve malicious files and execute further actions on the compromised website. The lack of effective controls to prevent vulnerability scanning, brute-force attempts, unauthorized administrative access, and suspicious file activity allowed the attackers to progress from reconnaissance to exploitation and ultimately deface the website. These weaknesses indicate that stronger patch management, secure administrator credentials, brute-force protection, access controls, file-upload restrictions, and continuous security monitoring were required to reduce the likelihood and impact of similar attacks.

2.5 Technical Timeline

Time (UTC) 2016-08-10	Attack Phase	Technical Activity	Evidence / Significance
21:37	Reconnaissance	The attacker used a web vulnerability scanner against imreallynotbatman.com.	The HTTP logs contain the acunetix_wvs string, identifying Acunetix as the scanner. The source IPv4 address was 40.80.148.42
21:37+	Reconnaissance	The scanner tested the Joomla web application for potential vulnerabilities and exposed information.	The scan identified weaknesses in the publicly accessible Joomla application.

21:45	Credential Access / Brute Force	The attacker began making repeated authentication attempts against the Joomla administrator interface.	Multiple authentication attempts were observed from the attacker infrastructure, indicating brute-force activity. The IP address used was 23.22.63.114.
21:48:05	Initial Access	The attacker successfully authenticated to the Joomla administrator account.	A successful login event was observed, indicating that the attacker obtained valid credentials.
21:52	Exploitation	The attacker used the compromised Joomla environment to upload or retrieve malicious files.	File activity associated with 3791.exe was identified in the logs.
21:52+	Command and Control / Payload Retrieval	The compromised web server communicated with the external host prankglassinebracket.jumpingcrab.com (23.22.63.114).	Network activity showed the compromised server communicating with the external infrastructure used by the attacker.
21:52+	Defacement	The attacker retrieved the image used for the website defacement from an external host.	HTTP GET activity showed the compromised website reaching out to external attacker-controlled infrastructure to retrieve the file.
Post-Incident	Containment & Recovery	Security analysts and DFIR personnel contained the simulated threat, removed the defacement content, and restored the website.	These actions represent the hypothetical containment and recovery phase of this home-lab exercise.

2.6 Nature of the Attack

In this section, we analyze the tactics, techniques, and procedures (TTPs) used by the unauthorized entity throughout the intrusion. The investigation identified a progression from reconnaissance and vulnerability scanning to brute-force attempts, unauthorized administrative access, malicious file retrieval, and website defacement. Evidence from VirusTotal analysis was used to identify the malicious IP addresses, external infrastructure, and files associated with the attack.

Detecting malicious files from VirusTotal

To better understand the tactics and techniques of the unauthorized group, we confirm first if the `prankglassinebracket.jumpingcrab.com` is a malicious domain.

Particularly, the one shown in the following screenshot.

The screenshot shows the VirusTotal interface for the IP address 23.22.63.114. A red arrow points to the IP address in the search bar. Below the search bar, the IP address is listed with its details: 23.22.63.114 (23.20.0.0/14) AS 14618 (Amazon.com, Inc.). The interface shows a 'Passive DNS Replication' table with columns for Date resolved, Detections, Resolver, and Domain. The table lists several entries, with the last entry highlighted in red: 2018-05-02, 3 / 91, VirusTotal, and prankglassinebracket.jumpingcrab.com. Below the table, there is a 'Communicating Files' section with columns for Scanned, Detections, Type, and Name. The table lists several files, with the last entry highlighted in red: 2026-06-23, 65 / 70, Win32 EXE, and ab.exe.

Further investigation are the following below, in which we found one of the related files that has the most malicious content: `MirandaTateScreensaver.scr.exe`.

The screenshot shows the VirusTotal interface for the file `MirandaTateScreensaver.scr.exe`. The file is listed in the 'Communicating Files' table with columns for Scanned, Detections, Type, and Name. The file is highlighted in red. Below the table, there is a 'Files Referring' section with columns for Scanned, Detections, Type, and Name. The table lists several files, with the last entry highlighted in red: 2026-06-07, 49 / 71, Win32 EXE, and MirandaTateScreensaver.scr.exe.

The result from VirusTotal appears that the domain `prankglassinebracket.jumpingcrab.com` is malicious.

III. Impact Analysis

The incident resulted in the unauthorized access and defacement of the public-facing website. The compromise caused website disruption and could negatively affect the organization's reputation and user trust. The attack also demonstrated weaknesses in the Joomla CMS and administrative security controls, requiring remediation and additional security measures to prevent similar incidents.

IV. Response and Recovery Analysis

4.1 Immediate Response Actions

Revocation of Access

- **Identification of Compromised Website:** Using Splunk Enterprise, the security team identified suspicious scanning, repeated authentication attempts, successful administrator access, and malicious file activity associated with imreallynotbatman.com.
- **Timeframe:** Malicious activity was first observed at approximately **21:37 UTC**, followed by repeated authentication attempts at approximately **21:45 UTC** and successful administrator access at **21:48:05 UTC**.
- **Method of Revocation:** As part of the simulated response, the compromised administrator account would be disabled, its credentials reset, active sessions terminated, and the identified malicious IP addresses blocked.
- **Impact:** Revoking the attacker's access would prevent further unauthorized activity and reduce the risk of additional modifications to the compromised website.

Containment Strategy

- **Short-term Containment:** The affected website would be isolated from external access while the malicious files, unauthorized changes, and attacker-controlled connections were investigated.
- **Long-term Containment:** Stronger administrative access controls, brute-force protection, network restrictions, secure file-upload controls, and continuous monitoring would be implemented to reduce the attack surface.
- **Effectiveness:** These containment measures would prevent the attacker from maintaining access or continuing to modify the website.

4.2 Eradication Measures

Malicious File Removal

- **Identification:** Splunk investigation identified suspicious files and activity associated with the compromise, including 3791.exe and agent.php.

- **Removal:** As part of the simulated response, identified malicious files and unauthorized web content would be removed from the compromised website.
- **Verification:** A follow-up investigation would be performed using Splunk logs and file integrity checks to verify that no known malicious activity or unauthorized files remained.

Vulnerability Remediation

- **Vulnerability Identification:** The investigation found weaknesses in the Joomla CMS that were identified during the attacker's vulnerability scanning activity.
- **Patch Management:** The Joomla CMS, associated extensions, and server components would be updated to supported and secure versions.
- **Security Hardening:** Unnecessary services and components would be disabled, administrative access would be restricted, and secure file-upload controls would be implemented.

4.3 Recovery Steps

Website Restoration

- **Backup Validation:** A known-good backup of the website would be validated before restoration.
- **Restoration Process:** The compromised website would be restored to its original, verified state after the malicious files and unauthorized modifications were removed.
- **Integrity Checks:** File integrity checks and cryptographic hashes such as SHA-256 would be used to verify that restored files match the approved versions.

System Validation

- **Security Measures:** Firewall rules, access controls, and monitoring rules would be updated to detect the identified malicious IP addresses, domains, and other indicators of compromise.
- **Operational Checks:** The website would undergo functionality and security testing before being returned to normal operation.

4.4 Post-Incident Actions

Monitoring

Enhanced Monitoring Plans: Splunk monitoring would be improved to detect vulnerability scanning, repeated authentication failures, successful administrator logins, suspicious file uploads, and communication with known malicious infrastructure.

Tools and Technologies: SPL correlation searches and alerts would be developed to detect the TTPs identified during this investigation.

V. Lessons Learned

Gap Analysis: The incident demonstrated weaknesses in Joomla security, administrator authentication, brute-force protection, file-upload controls, and monitoring.

Recommendations for Improvement: The organization should prioritize CMS patching, strong administrator credentials, multi-factor authentication, brute-force protection, restricted administrative access, secure file-upload controls, and continuous security monitoring.

Future Strategy: Future security improvements should focus on reducing the attack surface, strengthening web application security, improving detection capabilities, and regularly testing the website against common web application attacks.

Home Lab Note: The containment, eradication, recovery, and post-incident actions described above are simulated response actions for this BOTS v1 home-lab exercise. They represent recommended SOC/DFIR procedures rather than actions performed on the real website.